CYBER SECURITY (PECCS702E)

Course Outcomes and Suggestions for UT-II

Course Outcomes (COs)

After completing this course, students will be able to:

CO1: Explain the fundamentals of cyber security, cyberspace, the CIA triad, cyber threats, cyber warfare and cyber terrorism, and their implications for critical infrastructure and organizations.

(Bloom's Level: K1-Knowledge and K2 – Understand)

CO2: Classify types of hackers, cyber-attacks and malware, and analyze the stages of a system hack, from gaining access to covering tracks.

(Bloom's Level: K4 – Analyze)

CO3: Apply ethical hacking concepts, threat modelling, VAPT and security architecture principles, and devise defenses against social engineering and insider threats.

(Bloom's Level: K3 – Apply)

CO4: Demonstrate the cyber forensics investigation process, evidence handling and report writing, and plan an information security audit based on ISO 27001:2013.

(Bloom's Level: K6 – Create)

CO5: Interpret the provisions of the IT Act 2000 on e-commerce, e-governance, certifying authorities, offences and penalties, IPR in cyberspace, and network-layer security (IPSec).

(Bloom's Level: K5 – Evaluate)

Part A: MCQ and Short Questions (1 Marks)

Section I: Multiple Choice Questions

Q1. Capturing packets in transit on a network is called: **[CO2]**

(a) Spoofing (b) Sniffing
(c) Phishing (d) Pharming
Answer: (b) Sniffing

Q2. Hiding data inside an image file is known as: **[CO2]**

(a) Cryptography (b) Steganography
(c) Hashing (d) Tunneling
Answer: (b) Steganography

Q3. STRIDE is a model used for: **[CO3]**

(a) Encryption (b) Threat modelling
(c) Forensic imaging (d) Auditing
Answer: (b) Threat modelling

Q4. "Tailgating" is a type of: **[CO3]**

(a) Malware (b) Physical social engineering
(c) Network attack (d) Cryptanalysis
Answer: (b) Physical social engineering

Q5. A penetration test in which the tester has no prior knowledge of the target is: **[CO3]**

(a) White box (b) Grey box
(c) Black box (d) Clear box
Answer: (c) Black box

Q6. The document that records who handled evidence and when is the: **[CO4]**

(a) Audit trail (b) Chain of custody
(c) Incident log (d) Warrant
Answer: (b) Chain of custody

Q7. ISO 27001:2013 Annex A contains how many controls? **[CO4]**

(a) 93 (b) 114
(c) 133 (d) 150
Answer: (b) 114

Q8. Which section of the IT Act 2000 (as amended) deals with cyber terrorism? **[CO5]**

(a) 66C (b) 66D
(c) 66F (d) 67
Answer: (c) 66F

Q9. In IPSec, which protocol provides both encryption and authentication? **[CO5]**

Answer: (b) ESP

Section II: Short Answer Questions

Q1. Define cyber security. **[CO1]**

Answer: Protection of systems, networks, programs and data from digital attacks, damage or unauthorized access.

Q2. What is cyber terrorism**? [CO1]**

Answer: Use of computers or networks to cause fear, disruption or harm for political, ideological or religious goals, e.g., attacks on power grids.

Q3. Differentiate a hacker from a cracker. **[CO2]**

Answer: A hacker explores systems (possibly ethically); a cracker breaks security with malicious intent, e.g., to steal or damage.

Q4. What is privilege escalation**? [CO2]**

Answer: Gaining higher access rights than originally granted: vertical (user to admin) or horizontal (user to another user).

Q5. What is an insider threat? **[CO3]**

Answer: A security risk from people within the organization (employees, contractors) who misuse legitimate access.

Q6. Define a vulnerability and an exploit**. [CO3]**

Answer: Vulnerability: a weakness in a system. Exploit: code or a technique that takes advantage of that weakness.

Q7. What is volatile evidence? Give an example. **[CO4]**

Answer: Data lost when power is off, e.g., RAM contents, running processes, network connections.

Q8. What is a hash value's role in forensics? **[CO4]**

Answer: It verifies that the forensic image matches the original (integrity), e.g., using MD5 or SHA-256.

Q9. Who appoints the Controller of Certifying Authorities (CCA), and under which section? **[CO5]**

Answer: The Central Government, under Section 17 of the IT Act 2000.

Q10. Name two modes of IPSec**. [CO5]**

Answer: Transport mode (protects the payload only) and tunnel mode (protects the entire IP packet; used in VPNs).

Part B: Short Questions of 5-Marks

Module 2: Hackers and Cyber Crimes

1. What is sniffing? Explain active and passive sniffing and countermeasures against them. **[K2]**
2. Explain the system hacking cycle: gaining access, escalating privileges, executing applications, hiding files and covering tracks. **[K4]**
3. Explain the different methods of privilege escalation and the ways to prevent it. **[K3]**
4. Discuss common cyber-attacks (SQL injection, XSS, MITM, DoS) and the vulnerabilities they exploit. **[K2]**
5. Describe the techniques attackers use to hide files and cover their tracks (steganography, NTFS alternate data streams, log clearing, rootkits). **[K2]**

Module 3: Ethical Hacking and Social Engineering

6. Define ethical hacking. Explain its scope, limitations and the five phases of hacking. [K2]
7. Explain threats and attack vectors with suitable examples. [K2]
8. What is information assurance? Explain its pillars. [K2]
9. Explain the threat modelling process, using the STRIDE methodology as an example. [K3]
10. Explain Enterprise Information Security Architecture (EISA) and its components. [K2]
11. Differentiate between vulnerability assessment and penetration testing. Explain the types of penetration testing. [K4]
12. Explain the types of social engineering attacks (phishing, pretexting, baiting, tailgating, vishing). [K2]
13. What are insider threats? Discuss their types and strategies to prevent them. [K3]
14. Identify common social engineering targets in an organization and suggest defense strategies**. [K3]**

Module 4: Cyber Forensics and Auditing

15. What is cyber forensics? Explain its need and objectives. **[K2]**
16. Explain the computer equipment and storage media relevant to forensic investigation (HDD, SSD, USB, memory cards, RAM). [K2]
17. Describe the role and responsibilities of a forensic investigator. [K2]
18. Explain the forensic investigation process step by step, from identification to reporting. [K3]
19. How is network-based evidence collected? Explain the tools and challenges involved. [K3]
20. What is the chain of custody? Why is it critical for evidence to be admissible in court? [K2]
21. Explain the structure and guidelines for writing a computer forensics report. [K3]
22. What is an information security audit? Explain the types of audits and the steps involved. [K2]
23. Plan an information security audit for a college computer lab against a defined set of audit criteria. [K6]
24. Explain ISO 27001:2013: its clauses (4–10), Annex A domains and the PDCA cycle in ISMS. **[K2]**

Module 5: Cyber Ethics and Laws

25. Explain the objectives and salient features of the IT Act 2000. [K2]
26. Discuss how the IT Act 2000 supports e-commerce and e-governance (legal recognition of electronic records and digital signatures). [K2]
27. Explain the roles and functions of the Certifying Authority and the Controller of Certifying Authorities. [K2]
28. Explain the offences and penalties under the IT Act 2000 (Sections 43, 65, 66, 66C, 66D, 66E, 66F, 67). [K2]
29. Explain Intellectual Property Rights in cyberspace, covering copyright, trademark, domain name disputes (cybersquatting) and software piracy. [K5]
30. Explain the IPSec architecture: AH, ESP, IKE, Security Associations, and transport vs. tunnel mode. [K2]